

Foundations of Security Assessment

Security Assessment

A structured process to identify, analyze, and prioritize security weaknesses in systems, networks, and applications.

Frameworks to Guide Assessment

Use recognized standards to ensure structured evaluation:

National Institute of Standards and Technology (NIST) – Cybersecurity Framework (Identify, Protect, Detect, Respond, Recover)

Center for Internet Security (CIS) – Security best practices and benchmarks

Types of Security Testing (No Paid Tools Needed)

Vulnerability Assessment

Purpose: Find known weaknesses.

Free Tools:

- OpenVAS – Detects known vulnerabilities
- Nmap – Scans ports and services

Output:

- List of vulnerabilities
- Severity rating (CVSS)
- Recommended fixes

Penetration Testing

Purpose: Simulate real attacks in a controlled lab.

Free Tools:

- Kali Linux – Security testing OS
- Metasploit – Exploitation framework
- Nmap – Reconnaissance

Output:

- Proof of exploitation
- Risk impact demonstration
- Remediation guidance

Compliance Testing

Purpose: Ensure systems follow security standards.

Use:

- Center for Internet Security Benchmarks
- Internal security policies

Output:

- Gap analysis report
- Non-compliant configurations
- Improvement recommendations

VAPT Methodology (Vulnerability Assessment & Penetration Testing)

Objective

Follow a structured, repeatable approach to assess and test security using recognized methodologies and open-source tools.

VAPT combines:

- Vulnerability Assessment (identify weaknesses)
- Penetration Testing (exploit weaknesses safely to demonstrate impact)

Standard VAPT Phases

Planning Phase

Goal:

Define scope, objectives, rules of engagement, and legal authorization.

Key Activities:

- Identify target systems (IP ranges, domains, apps)
- Define testing type (black-box, gray-box, white-box)
- Establish communication plan
- Get written permission

Tool:

- Dradis (CE) – Collaboration and reporting tool for organizing findings

Output:

- Scope document

- Rules of engagement
- Testing timeline

Discovery Phase (Reconnaissance & Scanning)

Goal:

Identify attack surface and potential vulnerabilities.

Activities:

- Network scanning
- Service enumeration
- Web application scanning
- Banner grabbing
- Subdomain discovery

Tools:

- Nmap – Port scanning & service detection
- OWASP ZAP – Web application vulnerability scanning

Output:

- Open ports list
- Running services
- Identified vulnerabilities
- Attack surface map

Attack Phase (Exploitation)

Goal:

Safely exploit vulnerabilities to validate risk.

Activities:

- Exploit misconfigurations
- Test authentication bypass
- Attempt privilege escalation
- Validate remote code execution

Tool:

- Metasploit – Exploitation framework

Only exploit within approved scope.

Output:

- Proof of concept (PoC)
- Screenshots/evidence
- Impact analysis

Reporting Phase

Goal:

Communicate findings clearly to technical and non-technical stakeholders.

Include:

- Executive summary
- Risk ratings (CVSS)
- Technical details
- Business impact
- Remediation steps

You can use reporting templates from platforms like:

- Pentest-Tools.com

Output:

- Final VAPT report
- Risk prioritization matrix
- Remediation roadmap

How to Learn VAPT Effectively

Follow a Recognized Testing Framework

Practice using:

- OWASP Web Security Testing Framework (WSTG)

It provides:

- Structured test cases
- Step-by-step methodology

- Real-world attack scenarios

Build a Practice Lab

Recommended setup:

- Kali Linux attacker machine
- Vulnerable VM (e.g., Metasploitable, DVWA)
- VirtualBox or VMware

Practice Structured Workflow

Always follow this order:

1. Plan
2. Discover
3. Analyze
4. Exploit
5. Document

Never jump directly into exploitation.

Key Takeaways

- VAPT is methodology-driven, not tool-driven.
- Tools assist — structure ensures professionalism.
- Reporting skills are just as important as technical skills.
- Following frameworks like OWASP improves consistency.
- A visual VAPT process flow diagram
- A beginner VAPT lab setup guide
- A sample professional VAPT report template
- A 30-day VAPT learning roadmap

Security Standards & Compliance

Objective

Align security practices with recognized regulations and standards using freely available resources.

Key Security Standards

General Data Protection Regulation (GDPR)

- Applies to organizations handling EU residents' data
- Focuses on privacy, data protection, breach notification
- Key areas: data minimization, consent, encryption, accountability

Health Insurance Portability and Accountability Act (HIPAA)

- Protects medical information (PHI) in the U.S.
- Requires administrative, physical, and technical safeguards
- Includes risk analysis and access control requirements

ISO/IEC 27001

- International standard for Information Security Management Systems (ISMS)
- Focuses on risk management, policies, and continuous improvement
- Certification-based compliance model

How to Learn & Apply

Use:

- OWASP Top 10 – Prioritize the most critical web vulnerabilities

The OWASP Top 10 helps you focus on:

- Injection flaws
- Broken authentication
- Security misconfiguration
- Access control weaknesses

This bridges practical testing with compliance requirements.

Risk Assessment Basics

Objective

Prioritize vulnerabilities using structured scoring systems.

Security isn't just about finding vulnerabilities — it's about determining which ones matter most.

CVSS (Common Vulnerability Scoring System)

Use the official calculator from:

- National Vulnerability Database (NVD)

The CVSS score considers:

- Attack complexity
- Privileges required
- User interaction
- Impact on confidentiality, integrity, availability

Example Scoring:

Score Range	Severity
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10	Critical

Risk Matrix Method

A simple spreadsheet-based approach using:

- Google Sheets
- Microsoft Excel

Step 1: Define Likelihood

- Low
- Medium
- High

Step 2: Define Impact

- Low

- Medium
- High

Step 3: Combine into Risk Level

Impact \ Likelihood	Low	Medium	High
High Impact	Medium	High	Critical
Medium Impact	Low	Medium	High
Low Impact	Low	Low	Medium

This helps prioritize remediation efforts.

Practical Learning Approach

1. Study regulatory requirements (GDPR, HIPAA, ISO 27001).
2. Identify applicable controls.
3. Map vulnerabilities (from OWASP Top 10) to compliance requirements.
4. Score vulnerabilities using CVSS.
5. Rank them using a risk matrix.
6. Create a remediation plan.

Key Takeaways

- Compliance frameworks guide *what* must be protected.
- OWASP Top 10 guides *where to focus in web security*.
- CVSS quantifies technical severity.
- Risk matrices translate technical findings into business priorities.

Common Vulnerabilities

Objective

Identify common security flaws using hands-on labs and open-source tools.

Understanding vulnerabilities is easier when you see and test them in controlled lab environments.

Network Vulnerabilities

These affect infrastructure, servers, and services.

Common Issues

- Open unnecessary ports

- Weak or default credentials
- Outdated services
- Misconfigured firewalls
- SMB/FTP anonymous access

Tool for Discovery

- Nmap – Identifies:
 - Open ports
 - Running services
 - Service versions
 - OS detection

Example Findings

- Port 21 open → FTP service exposed
- Port 445 open → SMB service (possible misconfiguration)
- Old Apache version → Potential known CVEs

Web Application Vulnerabilities

These affect websites and web applications.

Common Web Flaws

SQL Injection (SQLi)

- Inject malicious SQL queries
- Can dump databases or bypass login

Cross-Site Scripting (XSS)

- Inject malicious JavaScript
- Can steal session cookies

Broken Authentication

- Weak password policies
- Session management flaws

Practice Environment

Recommended Web Lab:

- OWASP Juice Shop
 - Modern intentionally vulnerable web application
 - Includes SQLi, XSS, broken access control
 - Beginner-friendly

Practice Labs for Hands-On Learning

Metasploitable

- Deliberately vulnerable Linux VM
- Designed for network exploitation practice
- Good for learning:
 - Service enumeration
 - Exploitation basics
 - Privilege escalation

VulnHub

- Collection of downloadable vulnerable machines
- Realistic penetration testing challenges
- Multiple difficulty levels

How to Learn Effectively

Step 1: Set Up a Lab

- Use VirtualBox or VMware
- Install Kali Linux (attacker machine)
- Add Metasploitable or VulnHub VM (target)

Step 2: Follow a Structured Approach

1. Recon (Nmap scan)
2. Service enumeration
3. Identify vulnerability
4. Research CVE or exploit
5. Exploit in lab
6. Document findings

Step 3: Practice Web Testing

- Deploy OWASP Juice Shop
- Test for SQLi and XSS
- Understand how payloads work
- Learn remediation techniques

Key Takeaways

- Network vulnerabilities often involve misconfigurations and outdated services.
- Web vulnerabilities often involve input validation failures.
- Practice in safe labs like Metasploitable and VulnHub.
- Always document:
 - Vulnerability
 - Exploitation method
 - Impact
 - Fix recommendation

Documentation Fundamentals in Security Testing

Objective

Learn how to create clear, professional security reports using free tools and structured templates.

Good documentation is what turns technical findings into actionable security improvements.

Tools for Security Documentation

Dradis (CE)

Purpose:

Collaborative reporting platform for security assessments.

Features:

- Centralized findings database
- Evidence management
- Report generation
- Team collaboration

Best For:

- VAPT engagements
- Structured vulnerability tracking
- Multi-tester projects

CherryTree

Purpose:

Organized technical note-taking tool.

Features:

- Tree-structured notes
- Code formatting
- Screenshots & evidence storage
- Lightweight and offline

Best For:

- Capture commands used
- Store payloads
- Track enumeration steps
- Keep exploitation evidence

Standard Reporting Tools

You can also use:

- Microsoft Word
- Google Docs
- Markdown editors
- PDF generators

- ❖ The tool is less important than:
Clarity
Structure
Consistency
Professional tone

Basic Structure of a Security Report

Executive Summary

- High-level overview
- Overall risk rating
- Business impact
- Key recommendations

(Non-technical audience section)

Scope & Methodology

- Assets tested
- Dates of testing
- Tools used
- Testing limitations

Findings (Main Section)

Each finding should include:

- Title
- Severity (CVSS score if applicable)
- Description
- Proof of Concept (evidence/screenshots)
- Impact
- Remediation
- References (CVE, standards, etc.)

Risk Summary Table

ID	Vulnerability	Severity	Status
01	SQL Injection	Critical	Open
02	Open FTP Port	Medium	Open

Conclusion & Remediation Roadmap

- Prioritized fixes
- Quick wins
- Long-term improvements

Learn Documentation Skills

Practice in Labs

After testing:

- Document every command used
- Capture screenshots
- Write clear explanations

Use Free Templates from:

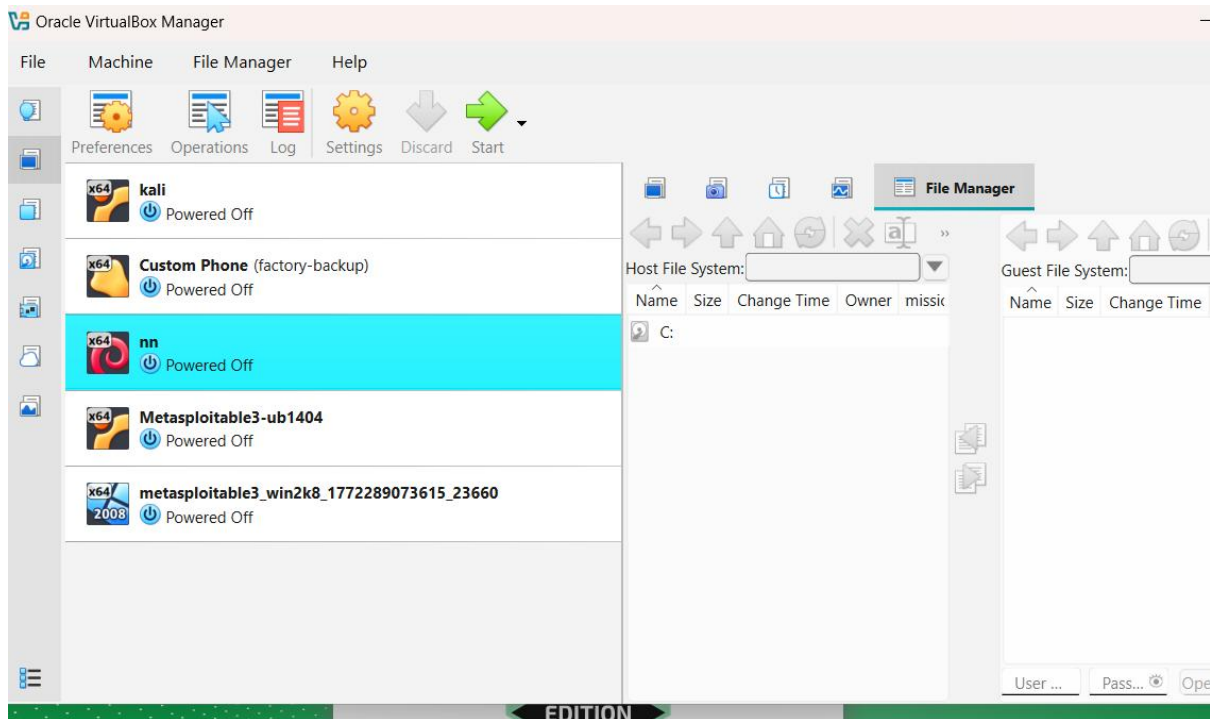
- GitHub
Search for:
- “penetration testing report template”
- “VAPT report template”
- “security assessment report template”

Key Takeaways

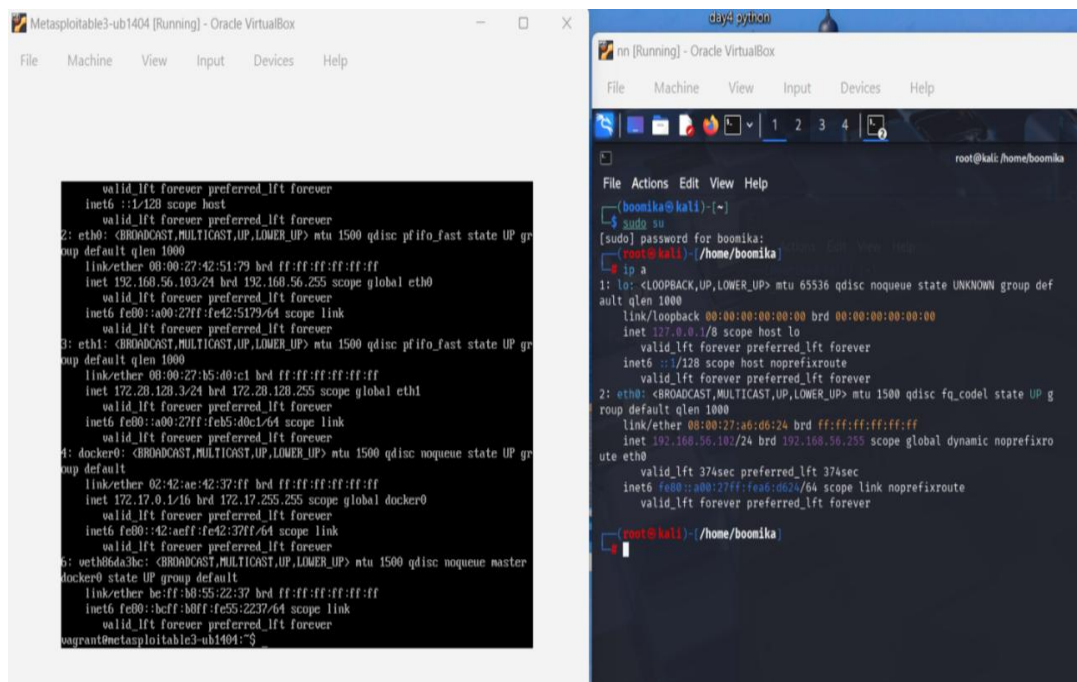
- Documentation is as important as technical skill.
- Tools like Dradis and CherryTree help structure findings.
- Templates improve professionalism and consistency.
- Clear reporting increases credibility and career growth.

Document Findings

Install Kali Linux.



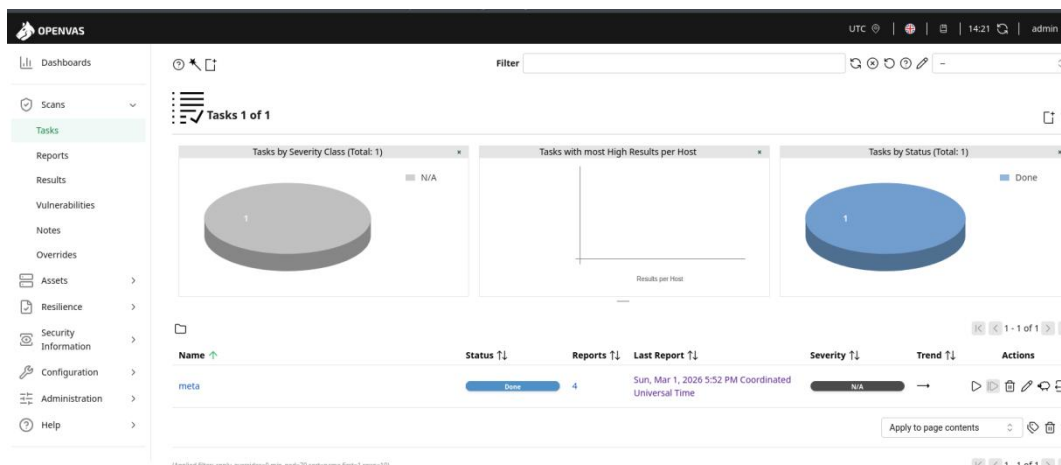
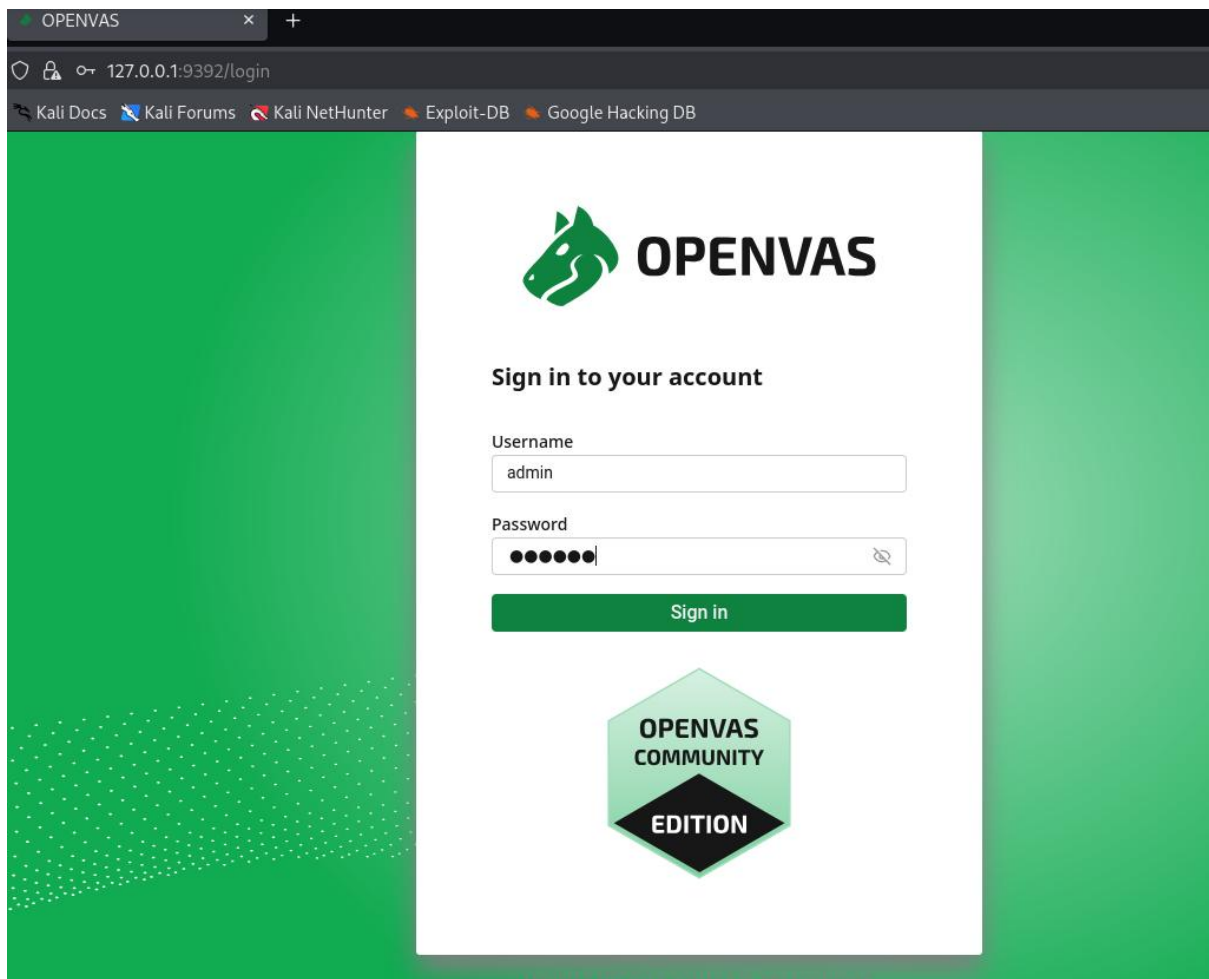
Download Metasploitable 3

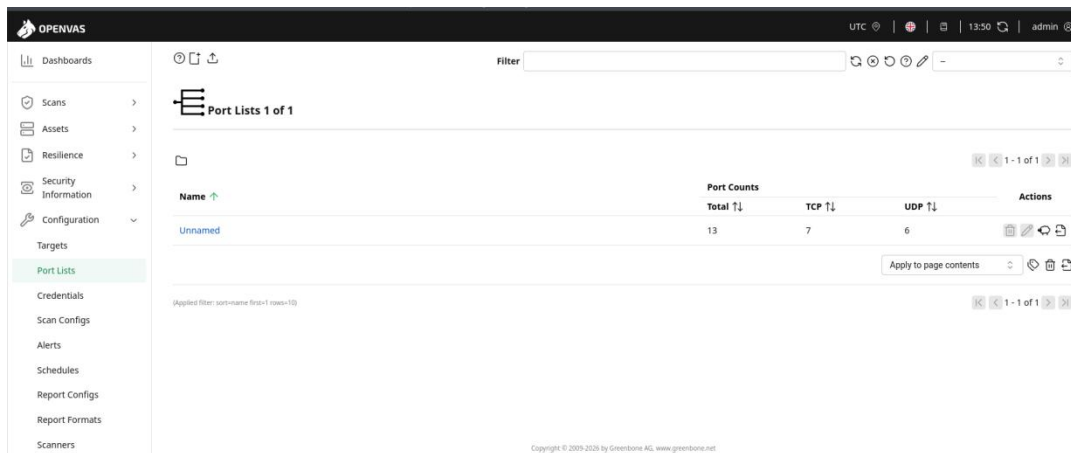


Gvm start

```
root@kali: /home/boomika/metasploitable3
Session Actions Edit View Help
(boomika@kali)-[~]
$ sudo su
[sudo] password for boomika:
(root@kali)-[/home/boomika]
# gvm start
Command 'gvm' not found, did you mean:
  command 'vm' from deb mgetty-voice
  command 'gem' from deb ruby-rubygems
  command 'gvmd' from deb gvmd
  command 'lvm' from deb lvm2
  command 'gpm' from deb gpm
  command 'gvb' from deb gvb
  command 'gum' from deb gum
  command 'kvm' from deb qemu-system-x86
  command 'gom' from deb gom
  command 'gm' from deb graphicsmagick
  command 'gv' from deb gv
Try: apt install <deb name>

(root@kali)-[/home/boomika]
# gvm-start
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
[>]
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392
● gsad.service - Greenbone Security Assistant daemon (gsad)
```



Tracking sheet

Report for 80 Port

HostIP	Port	Service	Vulnerability	CVSS	Severity	Description	Remediation
192.168.56.103	80	Apache Tomcat	Outdated Apache Tomcat	7.5	Medium	Apache Tomcat version outdated, vulnerable to RCE	Update Apache Tomcat to latest version

3x3 Risk Matrix in Excel:

Vulnerability	Likelihood	Impact	RISK
Apache Tomcat	3	1	Medium

Summary

Target: Metasploitable 3 (IP: 192.168.56.103)
 Scan Date: [FEB 28]
 Scanning Tool: OpenVAS (Greenbone Vulnerability Manager)
 Total Vulnerabilities Found: [4]
 High/Critical Issues: [0]
 Overall Risk Level: [Low / Medium]

Technical Details

Vulnerability 1: [Example: Apache Outdated Version]

Host: 192.168.56.103

Port: 80

Service: Apache HTTP Server

CVSS Score: [e.g 7.5]

Severity: Medium

Description:

The Apache HTTP Server is running an outdated version vulnerable to remote code execution attacks.

Impact:

Attackers could exploit this vulnerability to execute arbitrary code on the server, leading to full system compromise.

Recommendation:

Upgrade Apache HTTP Server to the latest stable version to mitigate this vulnerability. Refer to the official patch at <http://httpd.apache.org>